

Module 10

Applying Network Security Features

Learning Objectives

- Explain identity and access management concepts.
- Distinguish protocols and standards used for authentication and directory management.
- Use defense in depth techniques to ensure that only policy-compliant devices can connect to the network.
- Apply security rules, such as ACLs and content filtering, to manage network traffic.

Lesson 10.1

Authentication

Discussion



Boarding Pass

Passenger Name: Samantha Simons

Birthdate: 1-11-2001

Required to board:

- Passport
- Printed Ticket

Destination: Aruba

Ship: The Splash

Deck: 12

Cabin: 12345

Included:

- ✓ Beverages: All-inclusive
- ✓ Meals: A la carte
- ✓ Scuba diving excursion
- ✓ Resort shopping excursion

All onboard activities and purchases will be logged in your customer account.

Identity

Who she claims to be

Authentication

Proof that she is who she claims to be

Authorization

Where she is allowed to go and what level of access she will have once onboard

Accounting

Method for tracking and logging activity

Think About It: Access Control

Identity

An account or ID that uniquely represents a user, device, or process on the network

Authentication

Factor(s) used to prove a subject is who or what it claims to be

Authorization

Rights and permissions a subject is granted within a system or network

Accounting

Tracking of authorized/unauthorized usage of a resource by a subject

What are some examples of each of these in network security?



Authentication Methods

Something you know



Password

Something you have



Smart card

Something you are



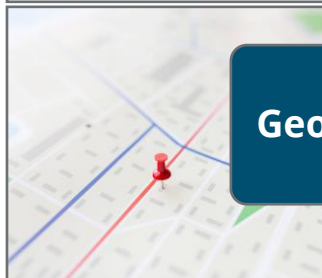
Fingerprint

Something you do



Gait

Somewhere you are



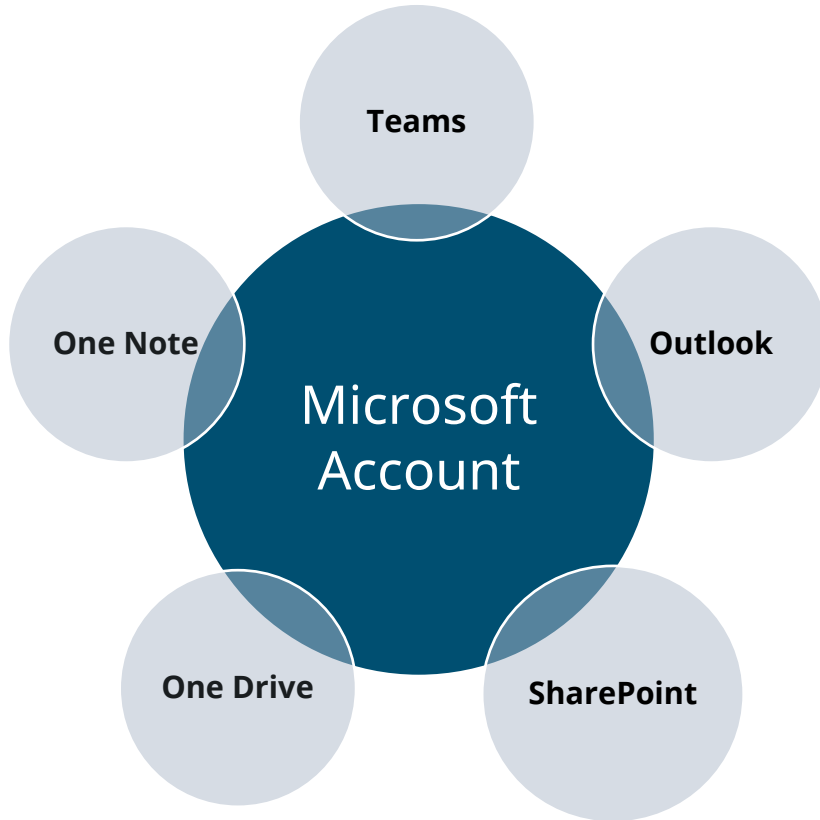
Geofencing

Somewhen you are



**Time
restrictions**

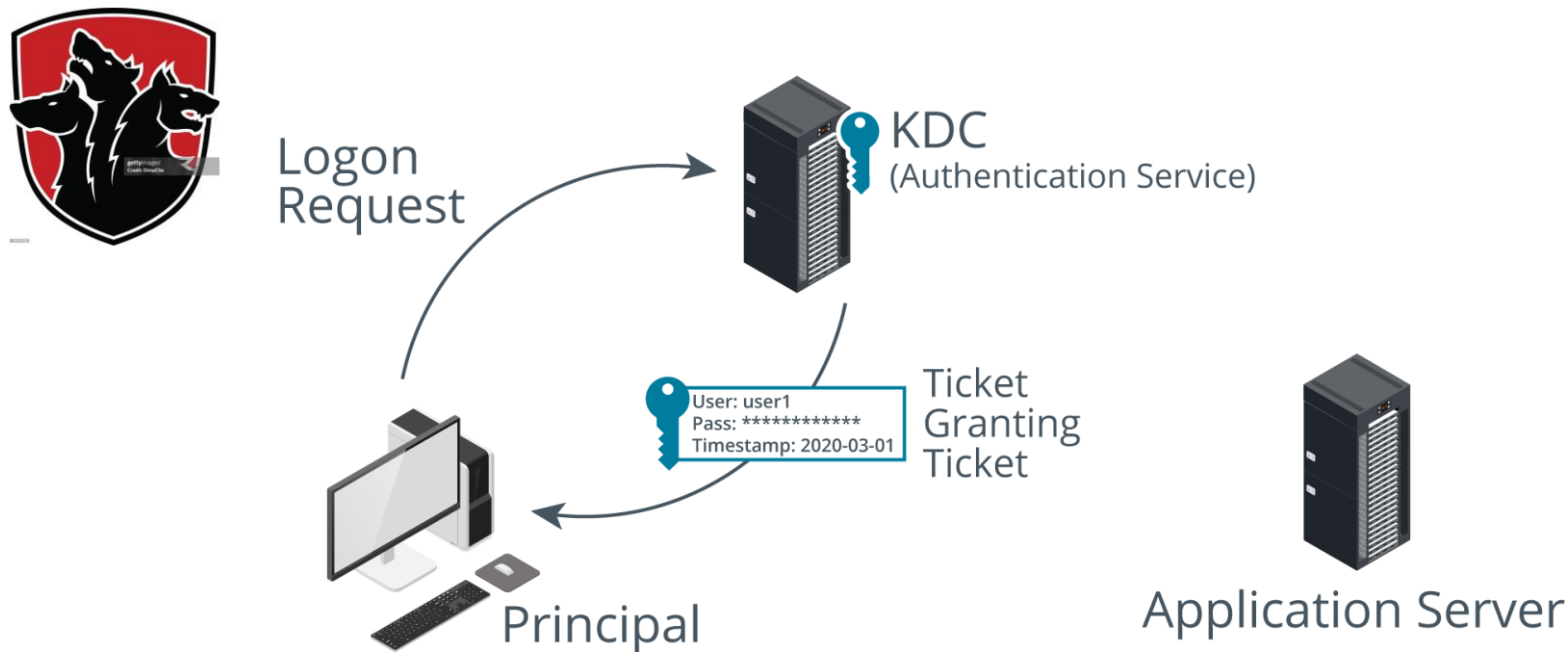
Single Sign-On



I'm so happy I
don't have to log
in to all these apps
one at a time!



Kerberos SSO Authentication



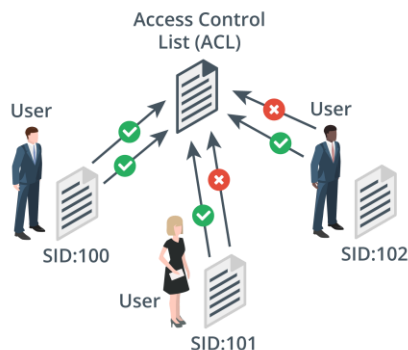
Lesson 10.2

Authentication and Account Management

Access Control Models

Discretionary Access Control (DAC)

Owner-controlled access

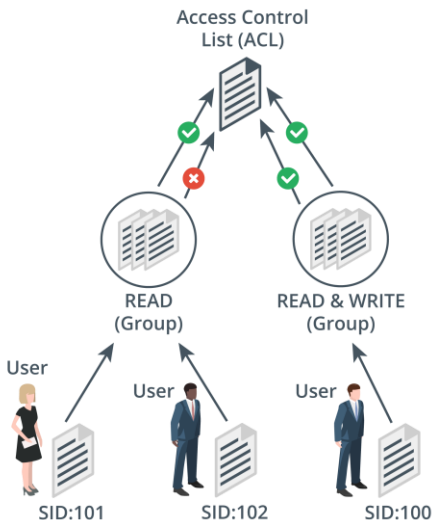


1

Assigning permissions directly to user accounts does not scale well

2

Instead, user accounts can be made members of different security groups



3

The security group is given permission on the object ACL and the user account inherits the permissions from the group

Role-Based Access Control (RBAC)

Role-based access

Access Management: Terms to Know

Privileged account

- Account for major system changes

Privileged Access Management (PAM)

- Controls to prevent abuse of privileged accounts

Least Privilege

- Granting users just enough rights to perform their job

Separation of Duties

- Dividing tasks to prevent misuse

Think About It: Who Needs Access?

**System
Administrator**

Developer

HR Manager

**Sales
Representative**

Employee records

Financial database

Server configurations

Office 365

Code repository

Security settings

HR software

Accounting software

Development tools

Customer database

Sales software

Payroll software



Lesson 10.3

Network Hardening

Defense in Depth Model

Data Access Controls Lists

Application Application hardening, antivirus

Host OS hardening, patching, BIOS password

Internal Network Subnets, VLANs, IDS/IPS

Perimeter Firewalls, VPN, IDS/IPS

Physical Security Guards, locks, tracking devices, fences

Policies, Procedures, and Awareness

User education, security documents

Device and Service Hardening

Each host and network device should be hardened.

What are some ways you can harden devices?



Lesson 10.4

Switch Security

Switch Security – Terms to Know

Network access control (NAC)

- System to authenticate/authorize access to a network

Switch

- Connects/manages communication on a network

Switch Ports

- Dedicated interface on a switch that connects devices

Port Security

Secure physical
access

Regularly update
switch firmware

Disable unneeded
ports

Configure MAC
filtering

Enable Router
Advertisement
Guard (RA)

Configure DHCP
snooping

Implement 802.1x
authentication
(EAP)

Think About It: What Would You Do?

ALERT! An unauthorized device was found connected to the network in the server room.

To prevent such occurrences, you decide to secure _____ access, using a secure server/equipment room and/or lockable cabinets).

You disable _____ to prevent unauthorized devices from being connected to the switch.

Additionally, you plan to enable _____ to limit the connections to known devices.

Finally, you enable _____ to inspect DHCP traffic for authenticity.



Think About It: What Would You Do?

ALERT! An unauthorized device was found connected to the network in the server room.

To prevent such occurrences, you decide to secure physical access, using a secure server/equipment room and/or lockable cabinets).

You disable unneeded ports to prevent unauthorized devices from being connected to the switch.

Additionally, you plan to enable MAC filtering to limit the connections to known devices.

Finally, you enable DHCP Snooping to inspect DHCP traffic for authenticity.



Lesson 10.5

Network Security Rules

Firewalls and Proxy Servers

Firewalls

- Filters all traffic and blocks/allows based on ACL
- Ensures only permitted traffic
- Filters traffic entering/leaving a network segment

Proxy Servers

- Deconstructs/analyzes packets to ensure rule compliance
- Enforces company policies
- Manages/redirects requests to control internet access

Content Filtering



Firewall Filtering Criteria

- Protocol
- Source and destination address
- Source and destination port
- Stateful inspection

Proxy Server Filtering Criteria

- URLs and domain names
- Content keywords
- Bandwidth usage
- Reputation of website

Common Firewall Misconfigurations

- Overly permissive ACL
- Overly prohibitive ACL
- Failure to apply an implicit deny
- Improper logging settings



Think About It: Two Truths and a Lie

Firewalls deconstruct and analyze packets to ensure rule compliance before forwarding.

Firewalls are positioned to filter traffic entering or leaving a network segment.

Proxy servers can filter based on content keywords.



Summary and Review

- **Access control:** Only authorized users and devices can access resources (physical & digital measures).
- **Defense in depth:** Layers of security (policies & mechanisms) safeguard data integrity, confidentiality, and availability.
- **Firewalls & Proxies:** Filter traffic and manage requests for network security and performance.
- **Content Filtering:** Fine-tune traffic with rules based on protocols, addresses, content, and more.